

**CEFET/RJ - CENTRO FEDERAL DE EDUCAÇÃO TECNOLÓGICA
CELSO SUCKOW DA FONSECA**

VAPOREON — Ferramenta de apoio ao pentest para iniciantes

Luis Guilherme Cantanhêde de Paiva

Prof. Orientador:
Ronilson Rodrigues Pinho

**Rio de Janeiro,
Novembro de 2024**

**CEFET/RJ - CENTRO FEDERAL DE EDUCAÇÃO TECNOLÓGICA
CELSO SUCKOW DA FONSECA**

VAPOREON — Ferramenta de apoio ao pentest para iniciantes

Luis Guilherme Cantanhêde de Paiva

Projeto final apresentado em cumprimento às
normas do Departamento de Educação
Superior do Centro Federal de Educação
Tecnológica Celso Suckow da Fonseca,
CEFET/RJ, como parte dos requisitos para
obtenção do título de Bacharel em Sistemas de
Informação.

Prof. Orientador:
Ronilson Rodrigues Pinho

**Rio de Janeiro,
Novembro de 2024**

DEDICATÓRIA

AGRADECIMENTOS

Texto

“Só seria fácil se não fosse difícil”

(Nome do autor)

RESUMO

Texto

Palavras-chaves: Palavra; Palavra; Palavra; Palavra; Palavra

ABSTRACT

Texto

Keywords: Palavra; Palavra; Palavra; Palavra; Palavra

Sumário

1	Introdução	2
1.1	Contextualização	2
1.2	Problema investigado	2
1.3	Motivação	3
1.4	Objetivos	3
1.5	Justificativa	3
1.6	Questões de Pesquisa para o Estudo de Caso	4
1.7	Delimitação do Estudo	4
1.8	Estrutura do Estudo	5
2	Fundamentação Teórica	6
2.1	Segurança da Informação	6
2.2	Testes de Penetração (Pentest)	6
2.3	Virtualização de Containers	8
2.4	Ferramentas de Testes de Penetração	9
2.4.1	Nmap	9
2.4.2	Nuclei	9
2.4.3	Nikto	9
2.4.4	Gobuster e Dirsearch	10
2.4.5	SQLMap e Commix	10
2.4.6	Metasploit	10
2.4.7	Netcat	10
2.4.8	Caído	11
2.5	Interface de Gráfica	11
2.6	Modelos de Linguagem de Grande Escala (LLMs) no Apoio ao Pentest	12
3	Revisão da Literatura / Trabalhos Relacionados	13
4	Proposta	14
5	Conclusão	15

Referências**16**

Lista de Figuras

Lista de Tabelas

Capítulo 1

Introdução

1.1 Contextualização

Com o advento das redes de computadores o mundo passou a ficar cada vez mais conectado, as pessoas passaram a interagir boa parte do tempo através de seus smartphones e computadores, fazendo da internet o principal meio de trégo de informações da idade contemporânea. Prevê-se que mais 125 bilhões de dispositivos IoT(Internet of Thinks - Internet das Coisas) sejam conectados a rede até 2030, o que indica números expressivos de dados trafegando em rede. Logo, as informações que atravessam o cyberspaço tornaram-se ativos de alto valor para as empresas.[Nizetic et al., 2020; Fernandes, 2018]

Através do vasto volume dados disponiveis em redes houve uma expansão da superficie de ataque sobre a qual cyberataques são elaborados e despendidos diariamente[Ahmad et al., 2023]. Em 2021, dados preocupantes mostraram uma alta incidência de ataques, 1 a cada 3 segundos, 1200 por hora. Além disso, as ofensivas têm sido cada vez mais sofisticadas, se utilizando de ataques de dia zero[Brooks, 2021].

1.2 Problema investigado

Em 2022, cerca de 3 milhões de vagas para cargos de segurança da informação ficaram em abertas, isso demonstra um inquietante indice de como está sendo o desenvolvimento dos profissionais da área. A área segue com elevados indices de dissonancia entre as qualificações dos candidatos e as habilidade necessárias para cargo, deixando em evidencia a importancia da formação profissional bem estruturada e o mais rápida possível para que a alta demanda seja suprido de forma rápida e com excelência[Goupil et al., 2022].

1.3 Motivação

A presente escassez de profissionais de cybersegurança se motiva, por muitas vezes, da dificuldade do iniciante em conseguir assimilar e empregar os diversos conceitos e práticas que a disciplina exige. Principalmente, quando se trata do uso intensivo da memória a fim de decorar os comandos de CLI necessários para o uso de praticamente todas as ferramentas para execução de testes de vulnerabilidades, enumeração e testes de penetração, o que torna a curva de aprendizagem significativamente íngreme para iniciantes [Alaryani et al., 2024].

1.4 Objetivos

Este trabalho tem como objetivo desenvolver e analisar uma ferramenta desktop GUI para apoio a testes de penetração, visando auxiliar o desenvolvimento acadêmico-profissional do estudante da área de TI. A fim de alcançar tal objetivo propõe-se:

- Pesquisar as principais técnicas e metodologias de testes de penetração utilizadas no mercado;
- Analisar as funcionalidades das ferramentas Nmap, Nuclei, Nikto, Caido, Gobuster, Dirsearch, Sqlmap, Commix, Netcat, Metasploit;
- Implementar a virtualização das ferramentas utilizadas através do Docker;
- Projetar e implementar uma interface gráfica;
- Implementar LLM para auxiliar o usuário durante a utilização de ferramentas;
- Avaliar o desempenho da ferramenta desenvolvida em ambiente controlado
- Documentar os resultados obtidos e propor melhorias futuras.

1.5 Justificativa

Apesar da ampla disponibilidade de ferramentas consolidadas para testes de segurança muitos estudantes e profissionais iniciantes encontram dificuldades práticas para usá-las de forma integrada e segura. A curva de aprendizado das interfaces em linha de comando, a diversidade de formatos de saída e a necessidade de montar fluxos reproduzíveis tornam o processo mais

custoso e propenso a erros[Alaryani et al., 2024]. Diante disso, este projeto propoe desenvolver o PentestAssist: uma aplicação desktop em Python com interface Tkinter que orquestre ferramentas, normalize suas saídas em um formato único, gere relatórios técnicos e ofereça fluxos guiados para quem está começando na área.

1.6 Questões de Pesquisa para o Estudo de Caso

A fim de orientar o desenvolvimento da ferramenta as seguintes questões foram levantadas:

1. Como a linguagem de programação escolhida pode ajudar?
2. Qual as dificuldade em executar aplicação em diversos Sistemas Operacionais?
3. De que forma a integração de ferramentas pode aumentar a eficiência da identificação de falhas?
4. Quais dificuldades os profissionais enfrentam ao realizar testes de penetração de forma manual?
5. Qual é o impacto da automatização dos testes de pentest no tempo e na qualidade da análise de vulnerabilidades?
6. Como a integração das ferramentas pode ajudar o profissionais iniciantes?
7. De que forma a LLM vai interagir com o usuário?

1.7 Delimitação do Estudo

O presente estudo se delimita ao desenvolvimento de uma aplicação GUI com o objetivo de integrar as seguintes ferramentas: Nmap, Nuclei, Nikto, Caido, Gobuster, Dirsearch, Sqlmap, Commix, Netcat, Metasploit; de forma virtualizada através de containers Docker. Além disso, conta com a implementação da LLM com o intuito de auxiliar o usuário em seus testes práticos. Não serão abordados desenvolvimento de aplicações web, questões reacionadas a segurança de equipamentos físicos e governança de TI.

1.8 Estrutura do Estudo

Este trabalho está organizado em cinco capítulos, além das referências bibliográficas e dos apêndices.

O Capítulo 1 apresenta a introdução ao tema, abordando a contextualização, o problema investigado, a motivação, os objetivos, a justificativa, as questões de pesquisa e a delimitação do estudo.

O Capítulo 2 reúne a fundamentação teórico, contemplando os principais conceitos relacionados à segurança da informação, testes de penetração, virtualização de ferramentas, integração de ambientes por meio do Docker e desenvolvimento de interfaces gráficas (GUI) em aplicações Python, uso de LLM para auxiliar o usuário, além da análise de trabalhos correlatos.

O Capítulo 3 descreve a metodologia empregada para o desenvolvimento do PentestAssist, detalhando as etapas de pesquisa, as tecnologias utilizadas (Python, Tkinter e Docker) e o processo de integração das ferramentas de pentest.

O Capítulo 4 apresenta o desenvolvimento da aplicação e os resultados obtidos, destacando a arquitetura do sistema, a interface desenvolvida, os testes realizados e a análise de desempenho em ambiente controlado.

Por fim, o Capítulo 5 traz as conclusões e considerações finais, evidenciando as contribuições do estudo, as limitações observadas e as perspectivas de aprimoramento e continuidade do projeto.

Capítulo 2

Fundamentação Teórica

2.1 Segurança da Informação

Inicialmente a Segurança da Informação foi regida por três princípios:

- **Confidencialidade:** este princípio estabelece que uma determinada informação só pode ser acessada por pessoas, sistemas ou entidades devidamente autorizadas, garantindo que seu conteúdo não seja divulgado ou exposto a terceiros sem permissão[Fontes, 2017].
- **Integridade:** assegura que os dados a serem transmitidos não devem, em hipótese alguma, ser alterado, corrompidos ou excluídos por terceiros durante o caminho do remetente até o destino[Fernandes, 2018].
- **Disponibilidade:** determina que os recursos e informações de um sistema devem estar acessíveis aos usuários autorizados sempre que solicitados, minimizando interrupções e garantindo a continuidade das operações[Moreno, 2019].

Com o avanço da tecnologia e a dinamização da internet apenas a tríade - CID - deixou de ser suficiente para garantir a segurança das informações. Portanto houve a necessidade de incluir outros três pilares: autenticidade, responsabilidade e a conformidade legal. A autenticidade refere-se à garantia de que indivíduos e sistemas são realmente quem afirmam ser; a responsabilidade assegura rastreabilidade das ações; e a conformidade legal assegura aderência a legislações como LGPD e normas internacionais de segurança. [ISO/IEC 27001:2013, 2013]

2.2 Testes de Penetração (Pentest)

Os testes de penetração consistem em técnicas sistemáticas de identificação, exploração e validação de vulnerabilidades em sistemas computacionais. O pentest simula o comportamento de um atacante real, permitindo avaliar o estado de segurança de uma organização de forma prática[Moreno, 2019].

Os testes podem ser classificados em:

- Caixa branca (white-box): o testador possui amplo conhecimento da infraestrutura;
- Caixa cinza (gray-box): conhecimento parcial;
- Caixa preta (black-box): sem conhecimento prévio do ambiente.

Fases do Processo de Testes de Penetração

Os testes de penetração são conduzidos de forma estruturada, seguindo fases bem definidas que permitem a identificação, exploração e análise de vulnerabilidades de maneira sistemática. Metodologias consolidadas, como o Penetration Testing Execution Standard (PTES), o NIST SP 800-115 e o OWASP Testing Guide, adotam abordagens semelhantes, garantindo padronização e reprodutibilidade dos testes [Moreno, 2019].

Reconhecimento e Coleta de Informações

A fase de reconhecimento tem como objetivo coletar informações iniciais sobre o alvo do teste, como endereços IP, serviços expostos, tecnologias utilizadas e possíveis vetores de ataque. Essa etapa fornece a base para as fases subsequentes, direcionando as ações do testador e reduzindo incertezas no processo [Stallings, 2017].

Enumeração de Serviços e Vulnerabilidades

Na fase de enumeração, aprofunda-se a análise dos serviços identificados, buscando versões de software, configurações e vulnerabilidades conhecidas. Ferramentas automatizadas auxiliam na correlação entre serviços detectados e falhas já documentadas, permitindo uma visão mais precisa da superfície de ataque [Moreno, 2019].

Exploração

A exploração consiste na tentativa controlada de explorar as vulnerabilidades identificadas, com o objetivo de comprovar sua existência e avaliar o impacto real sobre o sistema. Essa fase é conduzida de forma ética e autorizada, respeitando o escopo previamente definido, sendo fundamental para diferenciar vulnerabilidades teóricas de falhas efetivamente exploráveis [Stallings, 2017].

Pós-exploração

A fase de pós-exploração busca avaliar as consequências do acesso obtido, analisando possibilidades de escalonamento de privilégios, movimentação lateral e acesso a informações sensíveis. Essa etapa permite mensurar os riscos reais associados às vulnerabilidades exploradas, relacionando-os aos princípios de confidencialidade, integridade e disponibilidade [Moreno, 2019].

Geração de Relatórios

A etapa final consiste na documentação dos resultados obtidos durante o teste de penetração. O relatório deve apresentar as vulnerabilidades identificadas, evidências técnicas, impactos potenciais e recomendações de mitigação. Essa fase é essencial para comunicar os achados de forma clara e subsidiar a tomada de decisões por gestores e equipes técnicas [Moreno, 2019].

2.3 Virtualização de Containers

A virtualização é amplamente utilizada para possibilitar a execução isolada de aplicações em um mesmo ambiente computacional. Tradicionalmente, esse isolamento é obtido por meio de máquinas virtuais, que incluem sistemas operacionais completos, resultando em maior consumo de recursos. Como alternativa, a virtualização baseada em containers permite o compartilhamento do kernel do sistema operacional, oferecendo isolamento em nível de processos de forma mais leve e eficiente [Pahl, 2015].

O Docker consolidou-se como a principal plataforma de containers, possibilitando o empacotamento de aplicações juntamente com suas dependências, garantindo portabilidade e consistência entre diferentes ambientes de execução [Merkel et al., 2014].

No contexto da segurança da informação, o uso de containers favorece a execução isolada de ferramentas, reduzindo conflitos de dependências e impactos no sistema hospedeiro. Quando corretamente configurados, containers oferecem isolamento adequado para aplicações sensíveis, sendo apropriados para ambientes de testes de segurança e laboratórios educacionais [Combe et al., 2016].

No contexto deste trabalho, o Docker é utilizado para virtualizar Nmap, Nuclei, Nikto, Gobuster, Dirsearch, Sqlmap, Commix, Caido, Netcat e Metasploit, garantindo execução uniforme e independente do sistema operacional do usuário.

2.4 Ferramentas de Testes de Penetração

Ferramentas de testes de penetração são empregadas para apoiar a identificação, exploração e análise de vulnerabilidades em sistemas computacionais. Elas automatizam tarefas repetitivas, auxiliam na coleta de informações e permitem avaliar, de forma prática, a postura de segurança de redes, sistemas e aplicações. O uso dessas ferramentas é essencial para tornar o processo de pentest mais eficiente e sistemático, especialmente em ambientes complexos[Moreno, 2019].

A seguir, apresentam-se as principais ferramentas consideradas neste trabalho, classificadas de acordo com seu papel no processo de testes de penetração.

2.4.1 Nmap

O Nmap (Network Mapper) é uma ferramenta amplamente utilizada para reconhecimento e enumeração de redes. Seu principal objetivo é identificar hosts ativos, portas abertas, serviços em execução e possíveis sistemas operacionais. A fase de reconhecimento é fundamental para o sucesso do pentest, pois fornece informações iniciais que orientam as etapas subsequentes de análise e exploração[Stallings, 2017].

2.4.2 Nuclei

O Nuclei é um framework de varredura baseado em templates, empregado para a detecção automatizada de vulnerabilidades conhecidas e más configurações. Seu modelo baseado em assinaturas facilita a identificação rápida de falhas recorrentes em aplicações e serviços, contribuindo para a eficiência da fase de enumeração de vulnerabilidades [Moreno, 2019].

2.4.3 Nikto

O Nikto é um scanner de servidores web utilizado para identificar configurações inseguras, arquivos sensíveis expostos e vulnerabilidades conhecidas. Essa ferramenta auxilia na avaliação preliminar da segurança de aplicações web, permitindo detectar falhas comuns que podem comprometer o ambiente[Moreno, 2019].

2.4.4 Gobuster e Dirsearch

Ferramentas como Gobuster e Dirsearch são utilizadas para a enumeração de diretórios, arquivos e recursos ocultos em aplicações web. Essas ferramentas exploram listas de palavras para identificar caminhos não diretamente acessíveis, auxiliando na descoberta de superfícies de ataque adicionais. A enumeração detalhada de recursos expostos é uma etapa relevante na avaliação da segurança de aplicações[Stallings, 2017].

2.4.5 SQLMap e Commix

O SQLMap é uma ferramenta destinada à identificação e exploração automatizada de vulnerabilidades de injeção SQL, enquanto o Commix foca na detecção de falhas de injeção de comandos no sistema operacional. Ambas reduzem o esforço manual do testador ao automatizar testes complexos, permitindo validar o impacto real das vulnerabilidades encontradas [Moreno, 2019].

2.4.6 Metasploit

O Metasploit é uma plataforma abrangente para exploração de vulnerabilidades e realização de testes de pós-exploração. Ele permite avaliar as consequências práticas das falhas identificadas, auxiliando na compreensão do impacto sobre a confidencialidade, integridade e disponibilidade dos sistemas. Frameworks de exploração são fundamentais para validar a efetividade dos mecanismos de segurança existentes[Stallings, 2017].

2.4.7 Netcat

O Netcat é uma ferramenta de rede de propósito geral utilizada para estabelecer conexões TCP/UDP, realizar testes de conectividade e interagir com serviços de forma direta. Em atividades de pentest, é frequentemente empregado para validação de portas e serviços, simulação de comunicação cliente-servidor e apoio a testes que exigem troca de dados em baixo nível. Por permitir inspeção e interação com serviços de forma simples, o Netcat é útil em etapas de reconhecimento e validação de achados, complementando scanners automatizados e auxiliando na compreensão prática do comportamento de rede [Stallings, 2017; Moreno, 2019].

2.4.8 Caido

O Caido é uma ferramenta utilizada como proxy de interceptação para análise de tráfego HTTP/HTTPS, permitindo a inspeção, modificação e repetição de requisições entre cliente e servidor. Esse tipo de ferramenta é amplamente empregado em testes de segurança de aplicações web, pois possibilita observar o funcionamento interno das comunicações e identificar falhas relacionadas a autenticação, autorização e validação de entradas. A análise do tráfego de aplicações web é fundamental para compreender o comportamento das requisições e detectar vulnerabilidades que não são facilmente identificadas por scanners automatizados [Moreno, 2019].

Ao atuar como intermediário entre o navegador e a aplicação alvo, o Caido permite que o testador avalie de forma prática o impacto de alterações em parâmetros e cabeçalhos HTTP, auxiliando na identificação de falhas lógicas e de configuração. Dessa forma, a utilização de ferramentas de interceptação complementa o uso de scanners e frameworks de exploração, contribuindo para uma análise mais abrangente da segurança de aplicações web [Stallings, 2017].

2.5 Interface de Gráfica

Interfaces gráficas (Graphical User Interface – GUI) contribuem para a usabilidade de ferramentas de segurança da informação ao reduzir a dependência do uso direto de comandos em linha de comando, especialmente para usuários iniciantes. Em um cenário de crescente complexidade dos ataques cibernéticos e das ferramentas de defesa, soluções que abstraem detalhes operacionais favorecem a compreensão dos processos de testes de segurança e reduzem erros de execução [Ahmad et al., 2023].

Plataformas educacionais voltadas ao pentest tornam-se mais eficazes quando disponibilizam interfaces interativas, permitindo maior foco no aprendizado prático dos conceitos de segurança. Nesse contexto, o uso de interfaces gráficas auxilia na redução da barreira de entrada para estudantes e profissionais em formação [Alaryani et al., 2024].

No desenvolvimento em Python, o Tkinter apresenta-se como uma solução adequada por ser uma biblioteca nativa, simples e multiplataforma. A adoção do ttkbootstrap complementa essa abordagem ao proporcionar uma aparência visual mais moderna, mantendo a simplicidade da implementação. Assim, a interface gráfica adotada neste trabalho alinha-se aos objetivos educacionais da ferramenta proposta.

2.6 Modelos de Linguagem de Grande Escala (LLMs) no Apoio ao Pen-test

Modelos de Linguagem de Grande Escala (Large Language Models – LLMs) têm sido progressivamente incorporados a sistemas de apoio à segurança da informação, devido à sua capacidade de processar grandes volumes de dados textuais, interpretar resultados técnicos e fornecer explicações em linguagem natural. Esses modelos mostram-se particularmente úteis em ambientes complexos, nos quais a análise manual de informações pode ser custosa e sujeita a erros [Ahmad et al., 2023].

No contexto dos testes de penetração, LLMs podem atuar como ferramentas de suporte à interpretação de resultados, auxílio na compreensão de vulnerabilidades e orientação sobre boas práticas de segurança. O crescimento e a sofisticação dos ataques cibernéticos exigem abordagens que combinem automação e inteligência para apoiar profissionais e estudantes na tomada de decisão durante atividades de segurança [Ahmad et al., 2023].

Plataformas educacionais que integram inteligência artificial ao processo de aprendizado prático tendem a apresentar ganhos significativos na assimilação do conhecimento. O uso de IA em ambientes de pentest pode auxiliar usuários iniciantes ao fornecer explicações contextualizadas, sugestões de ações e suporte cognitivo durante a execução das ferramentas, reduzindo a dependência exclusiva de conhecimento prévio aprofundado [Alaryani et al., 2024].

É importante destacar que, no contexto deste trabalho, o uso de LLMs não se destina à automação completa de ataques, mas sim ao apoio educacional e interpretativo, auxiliando o usuário na compreensão dos resultados obtidos e no correto uso das ferramentas de testes de penetração. Dessa forma, a integração de LLMs contribui para tornar o processo de aprendizagem mais acessível, alinhando-se aos objetivos formativos da ferramenta proposta.

Capítulo 3

Revisão da Literatura / Trabalhos Relacionados

Capítulo 4

Proposta

Capítulo 5

Conclusão

Referências

- Rasheed Ahmad, Izzat Alsmadi, Wasim Alhamdani, and Lo'ai Tawalbeh. Zero-day attack detection: a systematic literature review. *Artificial Intelligence Review*, 56(10):10733–10811, 2023.
- Meera Alaryani, Shamsa Alremeithi, Fatima Al Ali, and Richard Ikuesan. Penthack: Ai-enabled penetration testing platform for knowledge development. In *European Conference on Cyber Warfare and Security*, volume 23, pages 27–36, 2024.
- Chuck Brooks. More alarming cybersecurity stats for 2021! *Forbes*, October, 24, 2021.
- Theo Combe, Antony Martin, and Roberto Di Pietro. To docker or not to docker: A security perspective. *IEEE Cloud Computing*, 3(5):54–62, 2016.
- Nélia O Campo Fernandes. Segurança da informação. 2018.
- Edison Luiz Gonçalves Fontes. Segurança da informação. *Saraiva Educação SA*, page 2, 2017.
- Francois Goupil, Pavel Laskov, Irdin Pekaric, Michael Felderer, Alexander Dürr, and Frederic Thiesse. Towards understanding the skill gap in cybersecurity. In *Proceedings of the 27th ACM Conference on on Innovation and Technology in Computer Science Education Vol. 1*, pages 477–483, 2022.
- ISO/IEC 27001:2013. ISO/IEC 27001:2013 – Information Technology – Security Techniques – Information Security Management Systems – Requirements. ISO/IEC Standard, 2013. Disponível em: <https://www.iso.org/standard/54534.html>.
- Dirk Merkel et al. Docker: lightweight linux containers for consistent development and deployment. *Linux j*, 239(2):2, 2014.
- Daniel Moreno. *Introdução ao Pentest*. Novatec Editora, 2019.
- Sandro Nizetic, Petar Soli, Luigi Patrono, et al. Internet of things (iot): Opportunities, issues and challenges towards a smart and sustainable future. *Journal of cleaner production*, 274: 1–32, 2020.
- Claus Pahl. Containerization and the paas cloud. *IEEE Cloud Computing*, 2(3):24–31, 2015.

W Stallings. Network security essentials: Applications and standards-william stallings.
Network Security Essentials Applications and Standards/William Stallings.–Harlow: Pearson Education Limited, pages 164–165, 2017.